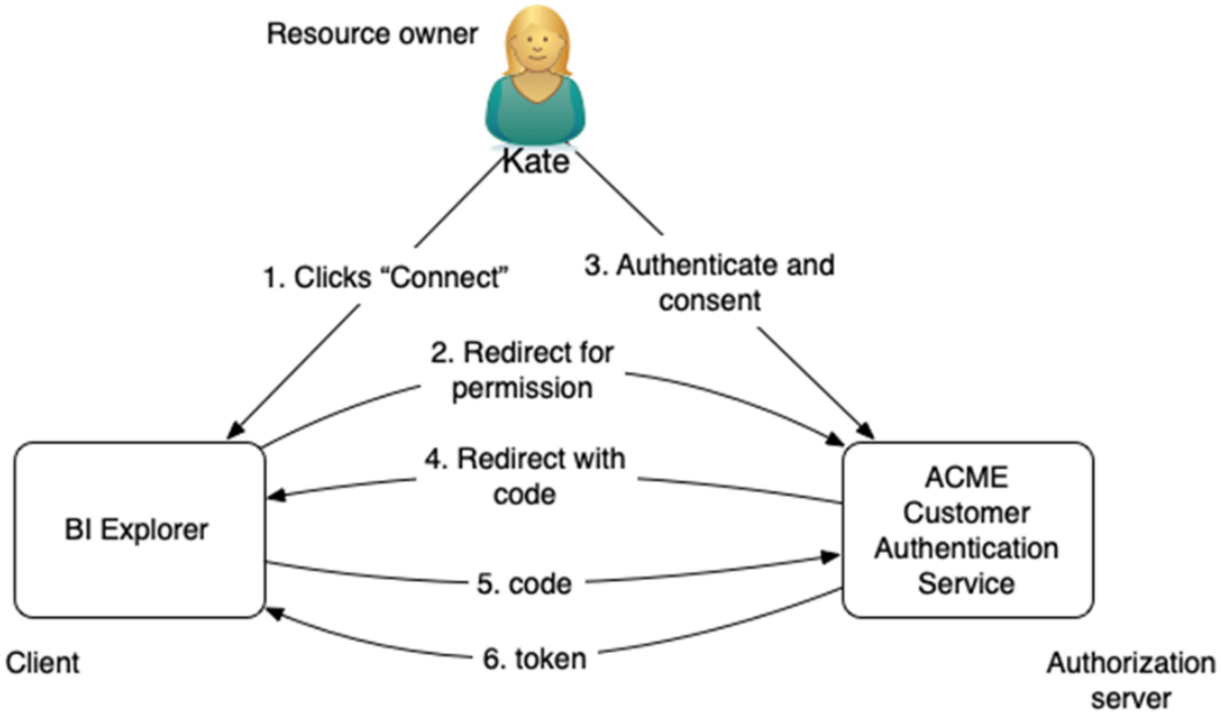


Figure 11.5 Authorization Code Grant. The resource owner's browser handles login and consent. ACME's authorization server provides a short-lived code, which the client then exchanges for an access token over a secure back channel.

The protocol involves several steps corresponding to the arrows in figure 11.5:

1. **Client initiation**. Kate clicks "Connect to ACME" in BI Explorer (the client).
2. **Client redirect**. The client then redirects Kate to ACME's authorization server, including human-readable descriptions of the requested scopes such as `collab:workspace.read`, `collab:doc.meta.read`, and `collab:event.subscribe`.
3. **Authentication and consent**. ACME's authorization server authenticates Kate using her usual credentials, then displays a consent screen showing the scopes BI Explorer has requested. Kate reviews the request and clicks **Allow**. Figure 11.6 shows the consent screen Kate sees when BI Explorer requests access. The scopes she approves determine what the resulting token can be used for.